

به نام خدا



تمرین چهارم امنیت داده و شبکه

نیم سال دوم ۱۴۰۴-۱۴۰۵

دانشکده مهندسی کامپیوتر

دانشگاه صنعتی شریف

موضوع امنیت شبکه

موعده تحویل ۱۹ تیر ۱۴۰۵، ساعت ۲۳:۵۹

طراحی تمرین توسط محمدعلی کاکاوند، محمدحسین چهکندی، علی اخگری، محمد حدادیان

۱ بررسی پروتکل‌ها

۱.۱ پروتکل مبتنی بر رمزنگاری نامتقارن

پروتکل زیر را که بر پایه رمزنگاری نامتقارن بنا نهاده شده است در نظر بگیرید. (N_B نمایانگر نانس تولیدی توسط B است)

$$A \rightarrow B : [ID]_A$$

$$B \rightarrow A : N_B$$

$$A \rightarrow B : E(PrivKey_A, N_B)$$

آ) پروتکل را توضیح دهید و بگویید برای چه کاری طراحی شده است. به طور مشخص توضیح دهید که هر پیام چه نقشی دارد و در پایان پروتکل چه تضمینی برای B فراهم می‌شود.

ب) چه نوع حمله‌ای به این پروتکل وارد است؟ (غیر از حملات پایه‌ای به الگوریتم‌های رمزنگاری)

۲.۱ پروتکل ایجاد کلید جلسه

پروتکل زیر را در نظر بگیرید که به A و B اجازه می‌دهد یک کلید جلسه تازه مانند K'_{AB} بسازند. فرض کنید این دو کاربر قبلاً کلید بلندمدت K_{AB} را با هم به اشتراک گذاشته‌اند.

$$1. A \rightarrow B : A, N_A$$

$$2. B \rightarrow A : E(K_{AB}, [N_A, K'_{AB}])$$

$$3. A \rightarrow B : E(K'_{AB}, N_A)$$

آ) ابتدا سعی می‌کنیم مقصود طراح پروتکل را بفهمیم.

چرا A و B فکر می‌کنند کلید K'_{AB} را با طرف مقابل به اشتراک گذاشته‌اند؟ پاسخ را به شکل زیر تکمیل کنید:

- A فکر می‌کند که کلید K'_{AB} را با B به اشتراک گذاشته است، چرا که ...
- B فکر می‌کند که کلید K'_{AB} را با A به اشتراک گذاشته است، چرا که ...

همچنین، چرا آن‌ها این کلید را تازه (fresh) می‌دانند؟ پاسخ را به شکل زیر تکمیل کنید:

- A فکر می‌کند که کلید K'_{AB} تازه است، چرا که ...
- B فکر می‌کند که کلید K'_{AB} تازه است، چرا که ...

ب) حال فرض کنید که کانال intercept شده است و دشمن در میانه راه نشسته است. A می‌خواهد با B پروتکل را مانند قبل اجرا کند اما C در میانه راه نشسته و پروتکل را از جانب B اجرا کرده و A فکر می‌کند که کلید جدیدی با B ساخته است در حالی که تنها با C مشغول تراکنش بوده است. اگر هر دو طرف بتوانند از طرف مقابلشان بخواهند که کلید را refresh کنند، نشان دهید چگونه مراحل این حمله انجام می‌شود. از این حمله نتیجه می‌شود که فرض طرفین در قسمت آ خدشه‌دار است.

ج) تغییری مختصر در پروتکل می‌تواند این حمله را ناکام بگذارد. راه حلی برای جلوگیری از این حمله پیشنهاد کنید.

۳.۱ پروتکل پرداخت PayDroid

سیستم پرداختی به نام PayDroid طراحی شده است. فرض کنید نام سرور PayDroid را "S" و Alice را "A" می‌نامیم. اگر A بخواهد مقدار X دلار به Bob ("B") بدهد، فقط همین پیام زیر را به سرور می‌فرستد:

$$A \rightarrow S : A, B, X, n, Cert_A, E(PrivKey_A, [X, n])$$

که در آن n یک عدد تصادفی است.

(آ) آیا این پروتکل امن است؟ توضیح مختصری دهید و اگر حمله‌ای به آن وارد می‌شود، آن را نشان دهید.

(ب) سعی کنید پروتکل را ترمیم کنید تا ضعیفی نداشته باشد.

۴.۱ توزیع کلید با سرور مرکزی

شبکه‌ای را در نظر بگیرید که در آن کاربران همگی به سرور S متصل می‌شوند تا برای ارتباط با همدیگر از سرور S کلید مشترک مخفی بگیرند. هر کاربر X با سرور یک کلید مشترک مخفی به نام K_X دارد. تمام پیام‌های بین کاربران و سرور با این کلید مشترک K_X رمز می‌شود.

فرض کنید کاربر A می‌خواهد با کاربر B پیغام M را به صورت رمز شده بفرستد. برای این کار نیاز به کلید مشترک R بین خود و B دارد. این کلید طبق پروتکل زیر تولید می‌شود:

$$1. A \rightarrow S : A, B, E(K_A, R)$$

$$2. S \rightarrow A : E(K_B, R)$$

$$3. A \rightarrow B : E(K_B, R), E(R, M)$$

(آ) توضیح دهید هر خط از این پروتکل به چه دلیل انجام می‌شود؟

(ب) آیا هکر Z قادر است به پیغام M دسترسی پیدا کند؟ در صورت پاسخ مثبت مراحل حمله را بنویسید و در صورت پاسخ منفی، توضیح دهید چرا نمی‌تواند.

۲ مدیریت کلید

۱.۲ سلسله‌مراتب کلید در یک سامانه بانکی

یک سامانه بانکی را در نظر بگیرید که از یک ساختار سه‌سطحی برای مدیریت کلیدها استفاده می‌کند. این ساختار شامل موارد زیر است:

- یک کلید اصلی ریشه (Master Key) با نماد MK که در یک HSM نگهداری می‌شود.
 - یک کلید رمزگذاری کلید (Key Encryption Key) با نماد KEK برای هر شعبه.
 - یک کلید رمزگذاری داده (Data Encryption Key) با نماد DEK برای هر نشست (Session).
- آ) یک سلسله‌مراتب کلید مطابق با نیازمندی‌های فوق طراحی کنید و نمودار آن را رسم نمایید.
- ب) اگر یک کلید DEK به مخاطره بیفتد، شعاع تخریب (Blast Radius) آن را مشخص کنید و توضیح دهید چه اطلاعاتی در معرض خطر قرار می‌گیرند.
- ج) اگر یک کلید KEK به مخاطره بیفتد، شعاع تخریب آن را تحلیل کنید و توضیح دهید چه دارایی‌هایی تحت تأثیر قرار می‌گیرند.
- د) فرآیند تعویض کلید (Re-keying) را در هر یک از سطوح MK، KEK و DEK توضیح دهید.

۲.۲ راهبردهای ذخیره‌سازی کلید

سه روش متداول زیر را برای ذخیره‌سازی کلیدهای رمزنگاری در نظر بگیرید:

- ذخیره‌سازی کلیدها به صورت متن آشکار (Plaintext) روی دیسک
 - رمزگذاری کلیدها با استفاده از یک کلید اصلی (KEK)
 - استفاده از ماژول امنیت سخت‌افزاری (HSM)
- آ) این سه روش را از دیدگاه محرمانگی (Confidentiality)، در دسترس بودن (Availability) و هزینه (Cost) با یکدیگر مقایسه کنید.
- ب) برای هر یک از روش‌های فوق، مدل تهدید (Threat Model) مناسب را مشخص کرده و توضیح دهید در چه شرایطی استفاده از آن روش قابل قبول و امن خواهد بود.

۳.۲ مشتق‌سازی کلید از راز مشترک

فرض کنید آلیس (Alice) و باب (Bob) یک تبادل کلید دیفی-هلمن (Diffie-Hellman) را با موفقیت انجام داده و به یک راز مشترک Z (Shared Secret) دست یافته‌اند. این دو کاربر برای برقراری یک کانال امن به سه مقدار مستقل نیاز دارند:

- یک کلید AES-256
- یک کلید HMAC-SHA256
- یک بردار مقداردهی اولیه (IV)

آ) توضیح دهید چرا استفاده مستقیم از Z به عنوان کلید رمزنگاری مناسب نیست.

ب) روشی مناسب برای تولید مقادیر فوق از روی Z پیشنهاد کنید و دلیل نیاز به چنین روشی را توضیح دهید.

۴.۲ فضای کلید مؤثر

فرض کنید یک توسعه‌دهنده کلیدهای AES-128 را در زبان پایتون با استفاده از تابع زیر تولید می‌کند:

```
random.randint(0, 2128)
```

همچنین مولد اعداد تصادفی با استفاده از `time.time()` مقداردهی اولیه (Seed) شده است.

آ) اگر مهاجم بداند کلید در یک بازه زمانی یک‌ساعته تولید شده است و دقت زمان برابر با 1ms باشد، اندازه فضای کلید مؤثر (Effective Key Space) را محاسبه کنید.

ب) نتیجه محاسبه فوق را با فضای کلید واقعی AES-128 مقایسه کرده و توضیح دهید این روش تولید کلید چه پیامدهای امنیتی‌ای دارد.

۳ امنیت TLS و IPsec

۱.۳ حملات علیه TLS

در پروتکل اینترنت، یک اتصال معمول TLS تنها نیازمند آن است که سرور خود را احراز هویت کند و کلاینت معمولاً گواهی دیجیتالی برای اثبات هویت خود ارائه نمی‌دهد.

آ) یک Handshake استاندارد TLS را در نظر بگیرید که از تبادل کلید Diffie-Hellman (DH) استفاده می‌کند. یک مهاجم فعال ارتباط را شنود می‌کند و از آنجا که کلاینت احراز هویت نشده است، تلاش می‌کند نشست را ربوده و خود را به جای کلاینت جا بزند.

برای این منظور، مهاجم پیام ClientKeyExchange کلاینت را که حاوی پارامترهای عمومی DH برای تولید Premaster Secret است رهگیری کرده و آن را تغییر می‌دهد.

توضیح دهید که چرا این تلاش برای ربودن نشست با شکست مواجه می‌شود و مشخص کنید دقیقاً در کدام مرحله از Handshake این دستکاری آشکار خواهد شد.

ب) فرض کنید کلاینت و سرور هر دو از TLS 1.3 پشتیبانی می‌کنند اما با نسخه‌های قدیمی‌تر نیز Backward-compatible هستند.

مهاجم تصمیم می‌گیرد یک Protocol Downgrade Attack اجرا کند تا طرفین را مجبور سازد به جای استفاده از یک نسخه مدرن و امن، از یک نسخه قدیمی‌تر و آسیب‌پذیر استفاده کنند.

در رابطه با این حمله به پرسش‌های زیر پاسخ دهید:

۱. مهاجم برای آغاز این حمله باید کدام پیام یا پیام‌های مبادله‌شده در طول Handshake را رهگیری و دستکاری کند؟
۲. در صورت موفقیت اولیه مهاجم، چه تغییری در نسخه پروتکل و پارامترهای امنیتی نشست ایجاد خواهد شد؟
۳. توضیح دهید پیاده‌سازی‌های مدرن TLS چگونه این نوع دستکاری را تشخیص داده و از موفقیت‌آمیز شدن حمله جلوگیری می‌کنند.

۲.۳ پیکربندی IPsec برای ارتباطات سازمانی

یک شرکت قصد دارد ارتباطات خود را با استفاده از IPsec ایمن‌سازی کند. نیازمندی‌های این شرکت در دو سناریوی مستقل در ادامه آمده است.

آ) دفتر مرکزی شرکت در تهران و شعبه آن در اصفهان نیاز دارند که تمام ترافیک بین دو شبکه سازمانی، هنگام عبور از اینترنت عمومی، محافظت شود. ارتباط از طریق درگاه‌های VPN دو سایت برقرار می‌شود. به پرسش‌های زیر پاسخ دهید:

۱. در این سناریو استفاده از AH مناسب‌تر است یا ESP؟ پاسخ خود را توجیه کنید.
۲. آیا باید از Transport Mode استفاده شود یا Tunnel Mode؟ دلیل انتخاب خود را توضیح دهید.
۳. ساختار بسته حاصل را رسم کرده و تمامی فیلدهای مهم Header را برچسب‌گذاری کنید. همچنین مشخص کنید کدام قسمت‌ها رمزگذاری شده و کدام قسمت‌ها تحت پوشش احراز اصالت قرار دارند.

ب) اکنون فرض کنید یکی از کارمندان شرکت از طریق یک شبکه هتل و پشت یک روتر NAT قصد دارد مستقیماً یک اتصال امن IPsec با سرور داخلی شرکت برقرار کند. به پرسش‌های زیر پاسخ دهید:

۱. توضیح دهید چرا استفاده از AH در این سناریو با شکست مواجه می‌شود.
 ۲. حتی در صورت استفاده از ESP چه پیچیدگی یا مشکلی ممکن است ایجاد شود؟
 ۳. توضیح دهید مکانیزم NAT Traversal (NAT-T) چگونه این مشکل را برطرف می‌کند.
 ۴. در این سناریو معمولاً از Transport Mode استفاده می‌شود یا Tunnel Mode؟ دلیل پاسخ خود را بیان کنید.
- ج) پس از استقرار VPN، مهاجم یک بسته قانونی محافظت‌شده با IPsec را که برای انتقال مبلغی میان حساب‌های بانکی شرکت استفاده شده است شنود می‌کند و همان بسته را یک ساعت بعد مجدداً ارسال می‌کند.
- در مورد این حمله، به پرسش‌های زیر پاسخ دهید:
۱. آیا این حمله علیه یک اتصال IPsec که به‌درستی پیکربندی شده باشد موفق خواهد بود؟ استدلال خود را بیان کنید.
 ۲. مکانیزم ویژه IPsec که برای مقابله با حملات Replay طراحی شده است را معرفی و تشریح کنید.
 ۳. اگر Anti-Replay Window گیرنده به اشتباه پیکربندی شده باشد (برای مثال بیش از حد بزرگ باشد یا غیرفعال شده باشد)، چه پیامدهای امنیتی ممکن است ایجاد شود؟

۴ اعطای مجوز و دور زدن آن در سیستم‌عامل‌های موبایل

سیستم‌عامل‌های موبایل هر برنامه را در یک محیط ایزوله (sandbox) اجرا می‌کنند و دسترسی پیش‌فرض آن به منابع حساس مانند موقعیت مکانی، دوربین، مخاطبین و شناسه‌های دستگاه را قطع می‌کنند. کارایی این جداسازی به‌طور مستقیم به کیفیت سازوکار اعطای مجوز (Permission) (Granting) وابسته است؛ یعنی همان روشی که با آن یک برنامه می‌تواند برای دسترسی به یک منبع محافظت‌شده اجازه بگیرد. در این سؤال نخست تکامل این سازوکار در عمل را بررسی می‌کنید، سپس نشان می‌دهید که چرا حتی پیشرفته‌ترین مدل‌ها نیز نقص بنیادینی دارند، و در نهایت به نمونه‌هایی می‌رسید که در آن‌ها یک برنامه بدون داشتن هیچ مجوزی به داده‌ی محافظت‌شده دست پیدا می‌کند.

۱.۴ تکامل مدل اعطای مجوز

دو رویکرد کلاسیک برای اعطای مجوز در سیستم‌عامل‌های موبایل وجود دارد:

- **فهرست نصب (Install-time Manifest):** برنامه فهرست کاملی از مجوزهای موردنیاز خود را اعلام می‌کند و کاربر هنگام نصب، آن را به‌صورت همه‌یا هیچ می‌پذیرد.
- **درخواست لحظه‌ای (Time-of-use Prompt):** کاربر در لحظه‌ای که برنامه به یک منبع نیاز دارد، با یک پنجره‌ی محاوره‌ای روبه‌رو می‌شود و دسترسی را تأیید یا رد می‌کند.

به موارد زیر پاسخ دهید:

- (۱) برای هر یک از دو رویکرد بالا، یک ضعف اصلی را که در عمل مشاهده می‌شود نام ببرید (یکی از جنس امنیت و دیگری از جنس کاربردپذیری) و توضیح دهید چرا آن ضعف، اعطای مجوز را بی‌اثر یا پرخطر می‌کند.
- (۲) اندروید تا پیش از نسخه‌ی ۶ از مدل فهرست نصب استفاده می‌کرد و سپس به مدل درخواست لحظه‌ای مهاجرت کرد. مشخص کنید این تغییر کدامیک از ضعف‌های بند قبل را برطرف کرد و کدامیک را همچنان باقی گذاشت.
- (۳) سه سازوکار زیر در نسخه‌های جدیدتر iOS و Android معرفی شده‌اند. درباره‌ی هر یک کمی جست‌وجو کنید و در یک تا دو جمله بنویسید که دقیقاً چه کاستی‌ای را در مدل اعطای مجوز هدف گرفته است:

- مجوز یک‌بارمصرف (One-time / “Only this time”)
- موقعیت تقریبی در برابر موقعیت دقیق (Approximate vs. Precise Location)
- شفافیت ردیابی برنامه (App Tracking Transparency) در iOS

۲.۴ دور زدن کامل سامانه‌ی مجوز

بخش پیشین درباره‌ی سوءاستفاده از مجوزی بود که برنامه آن را در اختیار دارد. اما حالت نگران‌کننده‌تر زمانی است که یک برنامه به داده‌ی محافظت‌شده دست می‌یابد در حالی که اصلاً مجوز آن را نگرفته است. دو راهبرد اصلی برای این کار وجود دارد:

- **کانال جانبی (Side Channel):** برنامه از مسیری به داده می‌رسد که سامانه‌ی مجوز آن مسیر را محافظت نکرده است.
- **کانال پنهان (Covert Channel):** دو برنامه با هم تباری می‌کنند؛ برنامه‌ای که مجوز دارد، داده را به برنامه‌ای که مجوز ندارد منتقل می‌کند.

به موارد زیر پاسخ دهید:

- (۱) تفاوت دقیق کانال جانبی و کانال پنهان را بیان کنید و توضیح دهید چرا هر دو، مدل تهدید مبتنی بر ایزوله‌سازی برنامه‌ها را نقض می‌کنند، اما به دو شکل متفاوت.

۲) برای هر یک از سه نمونه‌ی واقعی زیر مشخص کنید که کانال جانبی است یا کانال پنهان، داده‌ی هدف چه بوده و از چه مسیری به دست آمده است:

- برنامه‌ای موقعیت جغرافیایی کاربر را از روی فراداده‌ی (EXIF) عکس‌هایی استخراج می‌کرد که اجازه‌ی دسترسی به آن‌ها را داشت، بدون آنکه مجوز موقعیت مکانی را گرفته باشد.
- کتابخانه‌ای آدرس MAC نقطه‌ی دسترسی Wi-Fi و شناسه‌ی BSSID را می‌خواند و با نگاشت آن به یک پایگاه داده‌ی موقعیت، مکان کاربر را تخمین می‌زد، بدون مجوز موقعیت مکانی.
- یک SDK، شناسه‌ی دائمی دستگاه (مانند IMEI) را که برنامه‌ای مجوزدار به آن دسترسی داشت، روی حافظه‌ی مشترک می‌نوشت تا برنامه‌ی بدون مجوز نیز بتواند آن را بخواند.

۳) چرا مقابله با کانال جانبی برای سیستم‌عامل به‌طور بنیادی دشوارتر از اصلاح صرف پنجره‌ی درخواست مجوز است؟ پاسخ خود را با مفهوم سطح حمله‌ی غیرمنتظره (وجود مسیرهای دسترسی محافظت‌نشده‌ای که طراح در نظر نگرفته است) توضیح دهید.

۴) طراحی یک کانال پنهان. فرض کنید دو برنامه روی یک دستگاه نصب شده‌اند: برنامه‌ی A مجوز دسترسی به مخاطبین را دارد اما مجوز شبکه ندارد، و برنامه‌ی B مجوز شبکه را دارد اما به مخاطبین دسترسی ندارد. این دو برنامه نمی‌توانند مستقیماً با یکدیگر داده رد و بدل کنند، اما هر دو می‌توانند یک منبع مشترک سیستمی را که سیستم‌عامل آن را حساس نمی‌داند مشاهده کنند (برای نمونه وضعیت شارژ باتری، حجم اشغال‌شده‌ی حافظه‌ی پنهان، یا روشن/خاموش بودن صفحه).

- یک منبع مشترک انتخاب کنید و یک پروتکل ساده طراحی کنید که با آن A بتواند داده را بیت‌به‌بیت به B منتقل کند. سازوکار کدگذاری (نگاشت مقدار منبع به ۰ و ۱) و همگام‌سازی میان فرستنده و گیرنده را مشخص کنید.
- با فرض زمان‌بندی واقع‌بینانه‌ای که برای طرح خود در نظر گرفته‌اید، نرخ تقریبی نشت داده را بر حسب بیت بر ثانیه تخمین بزنید و بگویید انتقال یک شماره‌تلفن (فرض کنید حدود ۵۰ بیت) چقدر طول می‌کشد.
- نام ببرید چه عاملی در عمل نرخ این کانال را محدود می‌کند و چرا حتی یک نرخ بسیار پایین نیز می‌تواند تهدید جدی برای حریم خصوصی باشد.

راهنمایی: نمونه‌های بند ۲ و دسته‌بندی کانال‌ها برگرفته از پژوهش میدانی زیر است که در صورت تمایل می‌توانید برای تحلیل دقیق‌تر به آن مراجعه کنید:

Per-Android the of Circumvention Apps' of Exploration An Data: Your Leak to Ways ۵۰ " al., et Reardon J. ۲۰۱۹ Security USENIX, 'System" missions